पृ thak

airtel Payments Bank

YOUR REQUIREMENTS / HOW THEY ARE ADDRESSED / WHAT REMAINS

What you asked for. How Prṛthak addresses it.

User requirements and delivery mapping

Prepared for Pratik. This document records the requested microsegmentation product, explains how each requirement is achieved, and distinguishes delivered behavior from partial coverage and pending acceptance.

1 Central visibility
Servers, listening services and allowed sources

2 Learn traffic
Temporary source/port evidence, then periodic policy sync

3 Classify and apply
Business tags, DCs and reusable group policies

4 See changes
New listeners, vanished services and actionable alerts

38 traceable requirements. Later explicit requests remain requirements. Implementation choices such as queues, signing and connection pools are supporting additions, not substitutes for the requested features.

Snapshot: application 0.6.1, 31 October 2026. This is a requirements review copy. The real 20-server pilot and native RHEL/Ubuntu, Entra and DC/DR acceptance remain pending.

Copyright 2026 Airtel Payments Bank Limited. All rights reserved. Branding follows the existing project assets.

SCOPE AND INTERPRETATION

The product you requested

One standalone central tool to use Linux firewalld for host microsegmentation: discover the estate, learn required source-to-service access, manage that access centrally and show service/security changes.

Your original four outcomes

- A central dashboard that automatically lists servers, running services/ports and permitted source policy.
- Temporary traffic observation showing which sources hit monitored ports, including a last-hour view.
- Application, DC, zone, criticality and custom classification for grouping and reusable policies.
- A graphic view and alerts when a service that was up or allowed becomes unavailable.

Your later messages also define the product

Service groups, scoped auto-allow learning, existing-firewall management, metadata assignment, SSO/RBAC, safe enforcement, GUI operations, HA, backups, branding and the 5,000-server target are all retained in the numbered register. Your final installation preference is GUI configuration plus one installer command, without manual .env or agent JSON editing.

Delivery label	Meaning in this document
Implemented	The requested core code/UI workflow exists. Boundaries are stated alongside it.
Partial	A requested part remains limited, incomplete or unproven for the intended production estate.
Not implemented	The requested design option is not supplied by the current release.
Deferred	Native/DC execution was explicitly left for later; the real pilot awaits its prerequisites.

Implementation is separate from operational acceptance. Passing automated tests, showing a demo or delivering policy to virtual identities does not establish native firewall behavior, a working live tenant, WAN failover or production security clearance.

Pages 3-4 are the complete register. Pages 5-16 explain delivery by feature. Page 17 lists gaps; page 18 separates supporting additions; pages 19-20 give acceptance and evidence.

Source references [S1]

YOUR EXPLICIT REQUESTS

Requirements register: product and policy

Each item below came from your requests or later clarifications. Click a detail page for the achieved behavior and its limits.

ID	Requirement	Delivery	Page
R01	Standalone project, Prṛthak branding and Airtel appearance	Implemented	10
R02	Automatic enrollment and central server inventory	Implemented	5
R03	Discover services, actual ports and later changes	Implemented	5
R04	Allowed sources per service; destination implicit	Implemented	6
R05	One policy for groups or tag-selected servers	Implemented	6
R06	Reusable port groups and aligned multiple sources	Implemented	6
R07	Existing/common firewalld rule management and deny review	Partial	7
R08	Temporary learning and last-hour source/port evidence	Implemented	8
R09	Port-specific automatic learned access and visible policies	Implemented	8
R10	Suggested policy, review, target selection and CSV export	Implemented	8
R11	Custom tags and one manually defined DC per server	Implemented	9
R12	Individual/bulk assignment and exact-IP CSV profiles	Implemented	9
R13	Subnet DC assignment, nested exceptions and IP/DC conflicts	Implemented	9
R14	Combined filters and clickable filtered overview counts	Implemented	10
R15	Separate pages and top-right user settings menu	Implemented	10
R16	Advanced DC/cloud visual, status pulses and observed links	Implemented	10
R17	Alerts for services that were up or are policy-allowed	Partial	5
R18	Unexpected/closed-port and possible lateral-movement alerts	Partial	13
R19	Managed enforcement, lockout protection, rollback and history	Implemented	13

Statuses apply to the scope described on the detail page. Requirements are not marked complete merely because a related backend component exists.

Source references [S1-S15]

YOUR EXPLICIT REQUESTS

Requirements register: platform and rollout

Each item below came from your requests or later clarifications. Click a detail page for the achieved behavior and its limits.

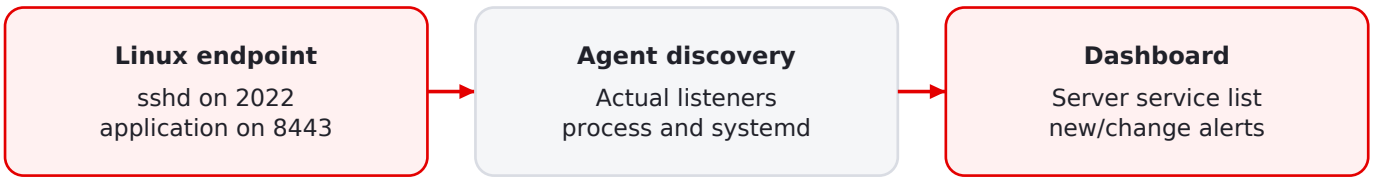
ID	Requirement	Delivery	Page
R20	Configurable agent URL/timing and scoped central polling	Implemented	11
R21	Lightweight RHEL 8/9 and Ubuntu systemd agent/installers	Implemented	11
R22	Inventory uses agent-reported IPs despite control-path NAT	Implemented	11
R23	Entra SSO and exactly three roles; Super Admin owns users	Implemented	12
R24	GUI configuration with one installer and no file editing	Partial	14
R25	Multi-controller DC/DR HA, shared data and GUI joining	Partial	15
R26	GUI cluster/replication credentials and service operations	Implemented	14
R27	GUI data-root path for application state and inventory	Implemented	14
R28	GUI PEM/PKCS#12 certificates and hostname generation	Implemented	14
R29	GUI change of the public application port	Implemented	14
R30	Database backups, scheduled runs and recovery controls	Implemented	15
R31	Button to remove default/demo data safely	Implemented	14
R32	5,000-server target with policy delivery inside 60 seconds	Partial	16
R33	Agent CPU/RAM, package, controller VM and Git details	Implemented	16
R34	Application-security review, VA and code remediation	Partial	17
R35	20-server pilot after checks; native/DC tests deferred	Deferred	19
R36	Illustrated guide: prerequisites, roles, ports and flows	Implemented	19
R37	Separate management/discovery/policy communication ports	Not implemented	17
R38	Application groups for Platform, Billing, Payments, etc.	Implemented	9

Statuses apply to the scope described on the detail page. Requirements are not marked complete merely because a related backend component exists.

Source references [S1-S15]

DISCOVERY AND AVAILABILITY

Automatic inventory and service health



Startup scan + periodic fresh discovery (900 seconds by default).

A cached heartbeat does not invent a new scan. Business application tags are assigned centrally.

R02 | Automatic enrollment and central server inventory IMPLEMENTED

You asked: Installing the endpoint agent should automatically enroll the server and make it visible centrally.

Achieved by: A one-use enrollment token bootstraps a certificate identity. The agent reports hostname, interface IPs and listeners; the dashboard updates inventory.

Boundary / remaining: A pending identity can appear before a successful report. File installation alone is not dashboard readiness; interrupted enrollment retries preserve identity.

R03 | Discover services, actual ports and later changes IMPLEMENTED

You asked: Show actual services and ports, including SSH on 22 or 2022; discover a newly started service about 15 minutes later and highlight it.

Achieved by: Startup and periodic scans read listeners plus process/systemd information. Server details show services; new/changed listeners create alerts and highlights.

Boundary / remaining: 900 seconds is the default fresh discovery interval. Failed scans keep the last successful inventory; a listening socket is not an application transaction check.

R17 | Alerts for services that were up or are policy-allowed PARTIAL

You asked: Alert graphically if a previously-up or policy-allowed service goes down.

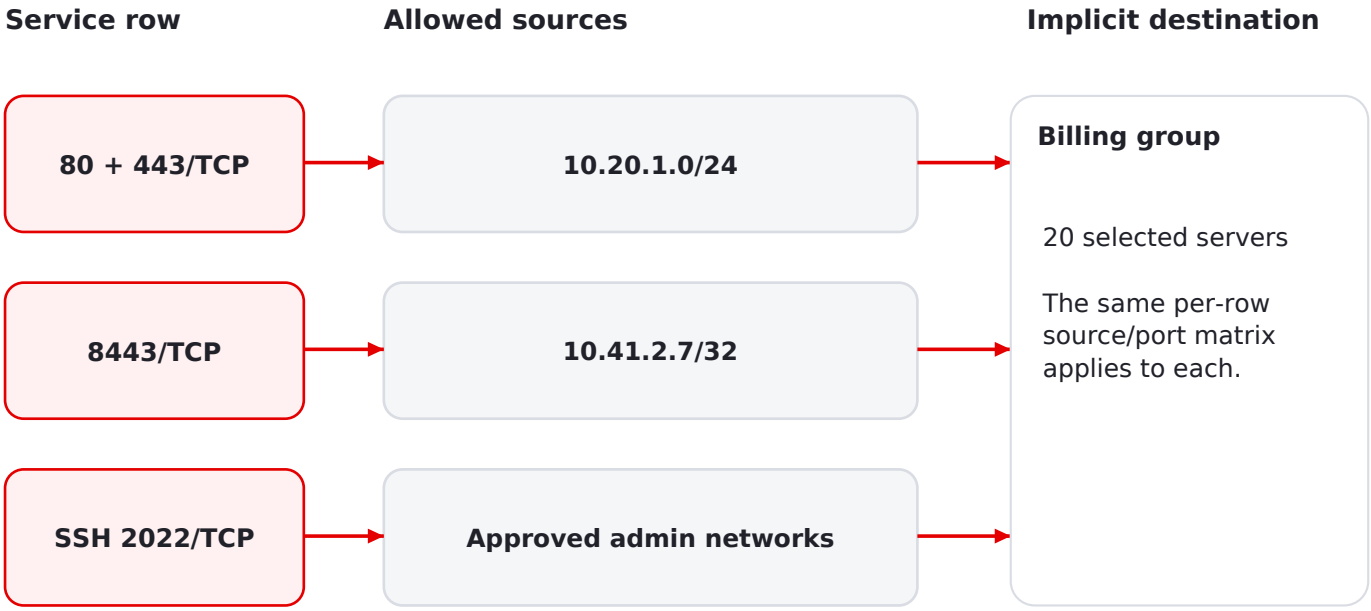
Achieved by: Previously observed listener disappearance, explicit expected services, stale heartbeats and reported firewalld outages have health/alert logic.

Boundary / remaining: PARTIAL: a port allowed by policy does not automatically become an expected service. An allowed-but-never-observed service can lack that automatic down expectation.

Source references [S2]

POLICY AND SERVICE MODEL

Source-based policies for server groups



R04 | Allowed sources per service; destination implicit IMPLEMENTED

You asked: Specify a service/port and allowed sources without a destination field.

Achieved by: The selected endpoint is the implicit destination. Per-service source rows compile to that endpoint's effective inbound policy.

Boundary / remaining: Current enforcement covers supported selected host TCP/UDP ports. Whole-host default deny, egress and forwarded/container paths are not supplied by this adapter.

R05 | One policy for groups or tag-selected servers IMPLEMENTED

You asked: Apply one policy to Billing's 20 servers, a saved group or matching tags.

Achieved by: Static/dynamic groups and tag selectors resolve targets. Membership/source changes recalculate affected effective bundles; each endpoint reports version/digest.

Boundary / remaining: Group membership changes intent. Live firewall changes still need the reviewed enforcement workflow.

R06 | Reusable port groups and aligned multiple sources IMPLEMENTED

You asked: Group several ports and align multiple permitted sources with the appropriate ports.

Achieved by: Reusable service groups expand ports within a service row. Explicit source CIDRs, source selectors and source groups can be combined per row.

Boundary / remaining: A row's sources intentionally apply to every port in that row's service group; separate rows keep different source sets apart.

Source references [S3]

BASELINE MANAGEMENT

Existing firewalld and common rules

R07 | Existing/common firewalld rule management and deny review PARTIAL

You asked: Show rules already present on 20 servers, including any-source openings; find common policy and modify/remove it globally, with two confirmations for deny changes.

Achieved by: Agents report runtime/permanent snapshots. The Firewall view classifies exposure and common rules. Selected changes have exact before/after previews, target/snapshot bindings and endpoint outcomes.

Boundary / remaining: PARTIAL: only supported service, port and validated rich-rule entries are editable. Zone targets, direct/NAT and unsupported entries remain view-only; this is not a universal firewalld editor.

How the requested double confirmation is implemented

Risky access changes use an exact requester review followed by a different current enabled Entra Admin/Super Admin and typed confirmation. The reviewed scope, rule snapshots, target IPs and protection bindings are rechecked before mutation. Both confirmations are bound to the same immutable reviewed change.

Example asked for	Current result
A common broad service/port opening	Visible in the baseline/common-rule views; edit/remove through the supported reviewed path.
An unsupported direct or NAT entry	Visible evidence can remain read-only; arbitrary rewrite is blocked.
An endpoint changes its rules after preview	Snapshot binding becomes stale; the old review cannot silently apply to the new state.
Twenty endpoints share intent	Use one central group policy for desired managed access; imported baseline edits remain a separate workflow.

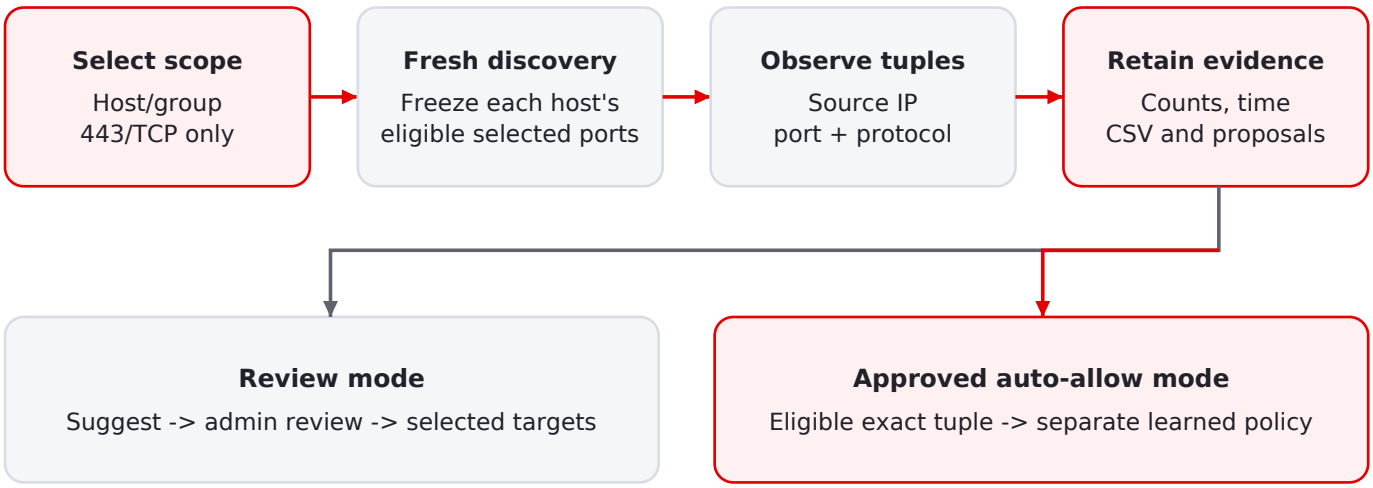
Acceptance example

On disposable native hosts, import an existing broad 8443 opening, inspect the shared-rule view, narrow one supported rule through independent review, then verify only the approved targets and exact rules changed. Native behavior and management-path safety are still acceptance work.

Source references [S4]

OBSERVED SOURCE-TO-PORT ACCESS

Temporary learning and automatic policy



R08 | Temporary learning and last-hour source/port evidence IMPLEMENTED

You asked: Learn which source IPs hit monitored services for at least an hour, then stop collection and keep periodic policy updates.

Achieved by: Bounded learning sessions can run for 3,600 seconds. Temporary log-only rules, a private spool and durable ingestion preserve observed source/port/protocol/time evidence.

Boundary / remaining: Capture is rate-limited and can be incomplete. The last-hour view is a query window; it is not proof that every packet or the preceding full hour was captured.

R09 | Port-specific automatic learned access and visible policies IMPLEMENTED

You asked: If learning/auto-policy is enabled on 443 only, automatically allow observed sources on 443 and show the resulting policies.

Achieved by: Fresh per-host discovery freezes selected eligible ports. After initial independent approval and required local opt-ins, eligible exact source/port tuples create separate learned allow policies.

Boundary / remaining: Protected management ports are excluded. Stop/expiry ends new additions and capture; already committed learned accepts remain until reviewed removal. Current GUI kits do not enable these local opt-ins.

R10 | Suggested policy, review, target selection and CSV export IMPLEMENTED

You asked: After learning, suggest policies for review/apply to selected servers or groups and export the source/service list.

Achieved by: Durable evidence supports exact recommendations, CSV export, selected-target previews and reviewed learned-policy editing/application.

Boundary / remaining: Observed clients are not automatically trustworthy. An additive accept does not reject other sources while an existing broad opening remains.

Source references [S5]

CENTRAL BUSINESS CLASSIFICATION

Tags, locations and subnet assignment



Per-field priority: Manual > exact-IP CSV > most-specific subnet > Unassigned.

R11 | Custom tags and one manually defined DC per server IMPLEMENTED

You asked: Create/customize DC name and location first; give a server multiple business tags but one DC.

Achieved by: Saved location IDs retain identity across renames. Central tags cover application, zone, criticality and custom key/value classifications.

Boundary / remaining: Agent-reported process/application identity does not create business ownership tags.

R12 | Individual/bulk assignment and exact-IP CSV profiles IMPLEMENTED

You asked: Assign tags/DC from an individual server or bulk selection, import IP/application details from CSV and let manual choices win.

Achieved by: GUI individual/bulk edits and exact-IP CSV profiles supply current or future classification. Manual per-field overrides outrank CSV, subnet and unassigned defaults.

Boundary / remaining: CSV profiles do not create enrolled identities. Explicit manual removals/Unassigned remain pinned until reset to automatic.

R13 | Subnet DC assignment, nested exceptions and IP/DC conflicts IMPLEMENTED

You asked: Map /8 or /16 to one DC, allow a more-specific /24 in another DC, and prevent the same IP/network belonging to different DCs.

Achieved by: Longest-prefix mapping resolves nested exceptions. Duplicate normalized CIDRs are rejected; conflicting DC claims for one reported IP are withheld and alerted.

Boundary / remaining: This is DC consistency, not independent IP ownership attestation. Same-DC duplicate/VIP IPs are permitted; ambiguous multi-owner CSV matching is rejected.

R38 | Application groups for Platform, Billing, Payments, etc. IMPLEMENTED

You asked: Platform, Billing and Payments application tags must all have corresponding server groups.

Achieved by: A dynamic application group represents each distinct centrally assigned application value and updates membership as classification changes.

Boundary / remaining: Automatic application groups derive from business tags, not guesses from listening ports.

Source references [S6]

YOUR REQUESTED PRESENTATION

Dashboard experience and estate visual

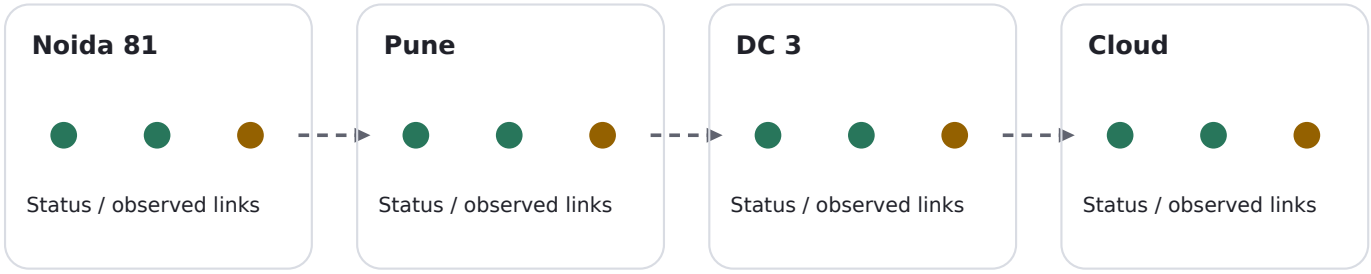


Illustration only. Production locations are manually created; lines require observed traffic evidence.

R01 | Standalone project, Prṛthak branding and Airtel appearance

IMPLEMENTED

You asked: Keep this a separate project named Prṛthak, with Hindi/English branding, Airtel red/white, the bank logo and rights footer; remove the cube.

Achieved by: The standalone project has a hybrid wordmark, existing project logo assets, red/white styling and copyright footer.

Boundary / remaining: Brand appearance is implemented; this document makes no separate organizational production-approval claim.

R14 | Combined filters and clickable filtered overview counts IMPLEMENTED

You asked: Combine filters such as Billing + port and make overview numbers open the matching filtered records.

Achieved by: Shared filter logic combines categories and carries scope into click-through Servers/Alerts and policy views.

Boundary / remaining: Values within a category generally use OR; different categories combine with AND.

R15 | Separate pages and top-right user settings menu IMPLEMENTED

You asked: Give Overview/Servers/etc. separate pages and put user settings in a top-right dropdown.

Achieved by: Distinct component URLs share the shell. The top-right identity menu includes profile/display preferences, permitted user management and mode-appropriate sign-out.

R16 | Advanced DC/cloud visual, status pulses and observed links

IMPLEMENTED

You asked: Use an advanced live-events feel with three DCs, cloud, blinking servers, links and highlights.

Achieved by: Topology groups DC/cloud locations with status/learning animation, selection, events, pause and fullscreen.

Boundary / remaining: Links show retained observations; after collection stops they do not represent fresh traffic. Status comes from current reports. Rendering is bounded and demo data is labelled.

Source references [S7]

ENDPOINT REQUIREMENTS

Agent behavior, polling and NAT

R21 | Lightweight RHEL 8/9 and Ubuntu systemd agent/installers IMPLEMENTED

You asked: Use a lightweight systemd agent for RHEL 8/9 and Ubuntu, with installers for the endpoints.

Achieved by: A static Go executable, hardened root systemd unit and matching RHEL/Ubuntu entrypoints are packaged for amd64 and arm64; the current Ubuntu target is 26.04.

Boundary / remaining: No Git, Python or Go runtime/compiler is required on an installed endpoint. Native OS/systemd/firewalld/SELinux acceptance remains deferred.

R20 | Configurable agent URL/timing and scoped central polling IMPLEMENTED

You asked: Change agent dashboard URL and timings in configuration, and manage polling globally or by Billing/Payments/group/tag scope from the platform.

Achieved by: GUI-generated kits establish the initial URL/timing. Central versioned polling defaults and ranked endpoint/group/tag overrides update running timers and receipts.

Boundary / remaining: Raw central defaults remain 60/900. Explicitly save 30/900 and review overrides for the measured freshness profile. Central polling does not silently enable firewall writes or migrate all controller URLs.

R22 | Inventory uses agent-reported IPs despite control-path NAT IMPLEMENTED

You asked: Show the server IP sent by the agent even when an LB/SNAT changes the connection source.

Achieved by: Authenticated reports supply inventory IPs. The controller does not replace them with the TCP peer or forwarded IP header.

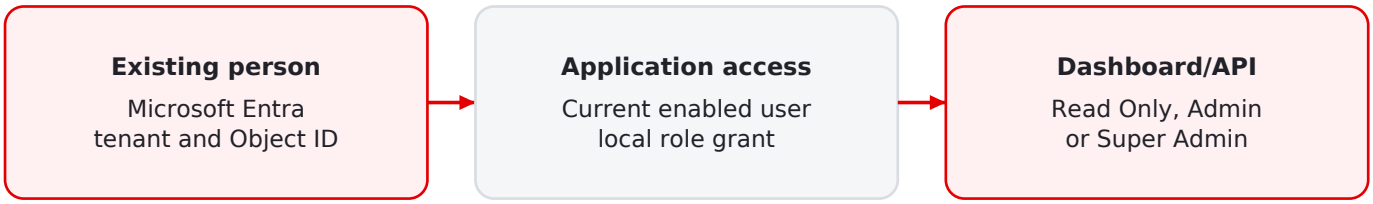
Boundary / remaining: Control-path NAT and application-traffic NAT differ. If a NAT device hides an application client before the endpoint kernel sees it, the original client IP cannot be reconstructed.

Communication point	Current implementation
Agent to controller	Outbound HTTPS, registered endpoint certificate; no inbound agent control listener.
Management safety witness	Controller reaches the endpoint's actual protected SSH port for a banner probe, without SSH login or remote shell.
Discovery and firewall integration	Local ss/process/systemd reads and local firewalld commands, not remotely opened discovery/firewall service ports.

Source references [S2] [S9] [S14]

ACCESS CONTROL

Entra login and exactly three roles



Directory authentication and application authorization are separate.

R23 | Entra SSO and exactly three roles; Super Admin owns users

IMPLEMENTED

You asked: Integrate AD-backed Microsoft Entra SSO with Read Only, Admin and Super Admin; only Super Admin may create any application user.

Achieved by: Single-tenant Web OIDC with PKCE verifies the existing tenant/Object ID. The application database grants one of exactly three roles. Entra email/groups/app-role claims do not promote access.

Boundary / remaining: Application user creation does not create directory accounts. Live tenant/MFA acceptance remains pending; MFA policy is configured in Entra.

Role	Requested and implemented authority
Read Only	View permitted operational information and export evidence; cannot mutate configuration or create users.
Admin	Manage operational servers, tags, groups, policies, learning and related reviews; cannot create any application user.
Super Admin	Admin capabilities plus user/role administration and privileged platform operations. No other role creates Admin, Super Admin or Read Only users.

How initial GUI setup protects the first login

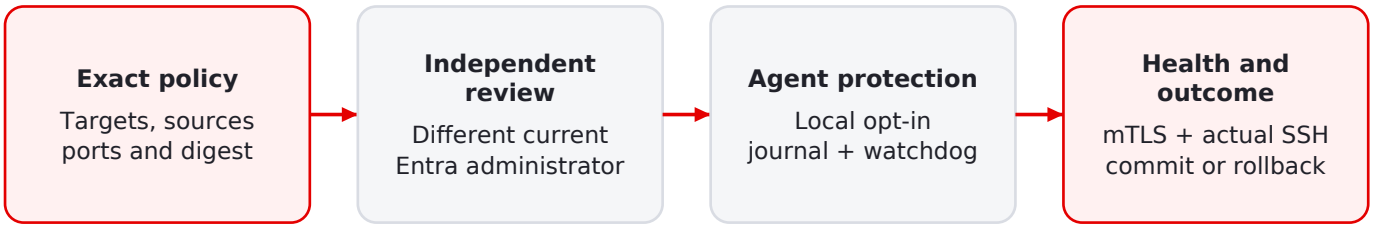
The installer supplies a private setup credential. The GUI stages tenant/client/callback/secret and the first Super Admin Object ID. A candidate Entra sign-in verifies that exact identity before activation, without creating an app user/session. The first normal sign-in creates the first Super Admin; the empty-user-table guard then stops additional bootstrap grants.

Sessions, CSRF/origin checks, current role/enablement and audit protect management APIs. Local access changes revoke sessions; directory-side disablement is evaluated at next sign-in. Active-provider replacement/secret rotation is outside the initial setup wizard.

Source references [S8] [S9]

FIREWALL CHANGES ON ENDPOINTS

Safe enforcement and security alerts



Saving a policy, downloading it and verifying kernel enforcement are different states.

R19 | Managed enforcement, lockout protection, rollback and history

IMPLEMENTED

You asked: Enforce managed policies on RHEL/Ubuntu with SSH/controller lockout protection, automatic rollback and version history.

Achieved by: Exact signed bundles and independent review precede local opt-in. The agent arms durable recovery and an independent systemd rollback unit, stages runtime changes, checks fresh controller/SSH reachability, commits and reads back rules.

Boundary / remaining: Local state survives a controller outage. Failure restores exact owned state; uncertain recovery blocks further mutation. Native custom-SSH, termination, reboot and rollback acceptance is still required.

R18 | Unexpected/closed-port and possible lateral-movement alerts PARTIAL

You asked: Generate an alert when a source hits unavailable ports, to help detect lateral movement.

Achieved by: An optional unexpected-port monitor creates bounded observations and a possible-scan alert for a multi-port pattern.

Boundary / remaining: PARTIAL: this is a rate-limited host heuristic, including a five-port/five-minute threshold, not complete multi-host lateral-movement correlation or proof of malicious intent. It requires a local instrumentation opt-in.

Meaning of policy version history

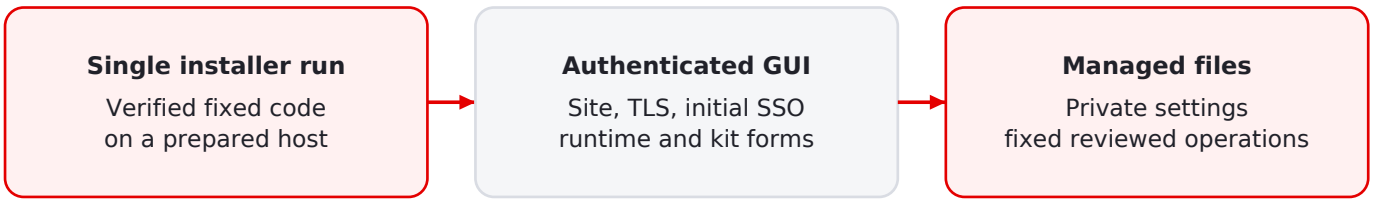
Only an effective policy change advances the per-endpoint access version. History, downloaded receipts, enforcement outcomes and drift remain distinct. Restoring older intent creates a new reviewed version; it does not erase the audit trail.

The selected-port adapter preserves unrelated rules. Changing a row, acknowledging an alert or restarting the agent is not evidence of successful kernel enforcement.

Source references [S4] [S8]

NO MANUAL APPLICATION-FILE EDITING

GUI configuration and platform controls



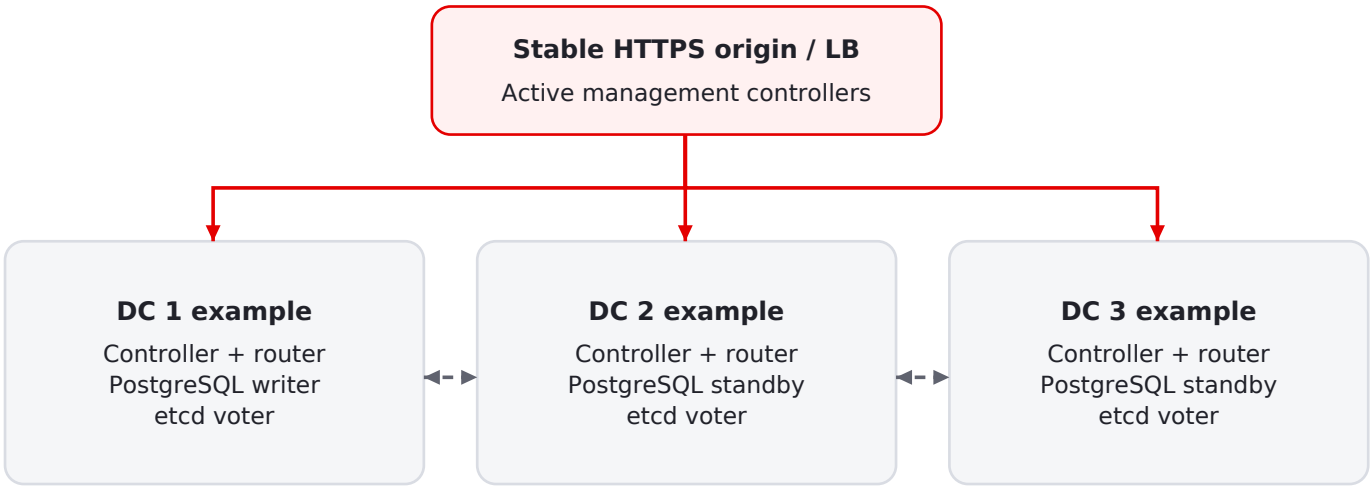
Requirement	How achieved and current boundary
R24 | GUI + one installer	Initial controller setup generates protected configuration. GUI agent kits avoid manual JSON/CA/token editing. PARTIAL across the full lifecycle: kits are monitor-only; security opt-ins, active Entra migration/rotation, post-enrollment origin migration and joined profile/file convergence are not completed by this wizard.
R26 | Credentials / services	GUI manages cluster/replication credentials privately and reviews owned controller/router/database/etcd operations. Existing passwords are not returned as plaintext; this is controlled service management, not arbitrary host-service execution.
R27 | Storage path	Reviewed data-root directory migration stops writers, copies/checks state and switches the pointer while retaining originals. The filesystem must already exist; GUI does not format/mount disks. Docker/OS logs remain outside DATA_ROOT.
R28 | TLS certificates	GUI supports PEM and PKCS#12 import plus hostname/SAN generation, candidate validation and verified rollback. Public HTTPS, endpoint issuance and internal cluster trust remain separate.
R29 | Application port	The public application port can change through a reviewed GUI operation. External LB/DNS/firewall rules, Entra callback registration and agent URLs are not automatically rewritten.
R31 | Default data button	Reviewed demo cleanup uses backup/protection checks, preserves real endpoints and disables reseeding. It is not a delete-all-real-servers action.

All GUI mutation rights follow the role model. OS preparation, protected release verification/extraction, bootstrap credential retrieval, filesystem permissions and secure file transfer remain prerequisites. A browser cannot enforce remote file ownership by itself.

Source references [S9] [S11] [S12]

SHARED DATA AND CONTINUITY

HA, DC/DR joining and backups



One database writer, full replica copies, three voters. Peer mesh simplified. Actual DC acceptance is pending.

R25 | Multi-controller DC/DR HA, shared data and GUI joining PARTIAL

You asked: Run the same installer at Noida/Pune/cloud, join using a peer IP and cluster password, share data and fail over through the LB; allow more management controllers.

Achieved by: GUI trust/fingerprint review and password joining establish membership. Three distinct-site PostgreSQL/etcd voters support shared data; additional management controllers can serve agents.

Boundary / remaining: PARTIAL operationally: two nodes alone do not activate this database HA design. There is one writer, practical connection/resource limits, external ingress work and native fencing/WAN/site-loss acceptance. Site-local controllers still depend on shared database availability.

R30 | Database backups, scheduled runs and recovery controls IMPLEMENTED

You asked: Provide database backup, scheduling and GUI recovery controls.

Achieved by: Paired database backups and daily/weekly/hourly schedules support timezone and retention settings. Reviewed recovery fences writers and verifies compatible candidates.

Boundary / remaining: Schedules start disabled; archive bytes/retention remain controller-local. Backups exclude private PKI/Vault/environment recovery material, which needs separate protection. GUI recovery needs current safety context/peers; it is not a complete archive-only offline DR or PITR procedure.

Active management controllers are not independent writable database copies. Extra controllers do not remove synchronous commit/WAN latency or establish automatic external LB failover.

Source references [S10] [S12]

REQUESTED SIZE AND DEPLOYMENT INFORMATION

Fleet scale and resource expectations

R32 | 5,000-server target with policy delivery inside 60 seconds PARTIAL

You asked: Support a final estate of 5,000 servers and keep policy updates inside 60 seconds, starting with a 20-server pilot.

Achieved by: Bounded HTTP concurrency/database pools support the recorded 5,000 virtual mTLS identity workload. A real API policy edit, publication and a full 30-second polling spread completed in 30.684 seconds.

Boundary / remaining: PARTIAL acceptance: this prior local workload is not 5,000 native agents, kernel enforcement, full-time learning, WAN or DC failover. Human review time and native apply latency are not certified by that result.

Requested sizing information (R33)	Recorded reference / starting recommendation
Passive agent memory	10.42 MiB median; 12.50 MiB high-water; agent plus active helpers 56.79 MiB sampled peak.
Passive CPU, percent of one core	Agent 0.046% after startup; including completed helpers 0.216%; including startup 1.675% average.
Pilot controller VM	4 vCPU, 8 GiB RAM, 80 GiB OS/Docker + 100 GiB data SSD.
5,000 management-only / combined voter	8 vCPU / 16 GiB; combined controller/database voter 8 vCPU / 32 GiB. Data SSD starting allocations 100 / 300 GiB.
Current 0.6.1 packages	amd64 agent 3,425,793 bytes; ARM64 agent 3,082,772 bytes; controller source 642,333 bytes. Signed fixed code is separate from private GUI kits.
Git and runtime dependencies	Git is optional source distribution, not runtime. Endpoints need no Go/Python runtime. Controller source installation needs approved image/package access; a full offline image installer is not supplied.

R33 is delivered as documentation and reference measurements, not a resource SLA. The historical 95-second Ubuntu-container passive run predates current GUI kit changes, used an empty policy and 60/900 timing, and excluded firewalld/kernel/journal costs. Native 0.6.1, learning bursts, larger policies and long-running behavior require measurement. No hard CPU/RAM limit is configured.

Source references [S13] [S14]

EXPLICIT PARTIAL COVERAGE

Remaining gaps against your requests

These are requirement gaps or acceptance limits, not silently reclassified optional features. This document records them; it does not claim they were fixed during document creation.

ID	Remaining point to close
R07	Broader existing-rule management is view-only outside the supported service/port/rich-rule subset.
R17	Automatically derive expected-service health from policy-allowed ports, including allowed-but-never-observed services.
R18	Expand bounded unexpected-port heuristics if full multi-host lateral-movement detection is required.
R24	GUI lifecycle for local enforcement/auto-allow opt-ins, active Entra provider/secret changes and joined profile/file convergence is incomplete.
R25	Validate native three-voter fencing, site partitions, shared-writer failover, external LB behavior and actual DC/DR recovery.
R32	Establish the 60-second target on the real estate, actual policy/source sizes and WAN/failover load, separately from local virtual delivery evidence.
R34	Complete residual upstream/container VA remediation and intended-environment security acceptance; historical fixes are not fresh 0.6.1 production clearance.
R37	Separate management, discovery and policy listeners are not implemented. Current routes share one configured HTTPS listener.

R34 | Security review you requested

The scoped application assessment recorded confirmed code findings and remediation, followed by regression checks. Vendor/container findings and physical/tenant/network acceptance remain open. The 0.6.1 setup/kit additions have targeted role, OIDC, CA, private-file and integration tests; they are not presented as a new full VA of the release.

R37 | The communication-port design option

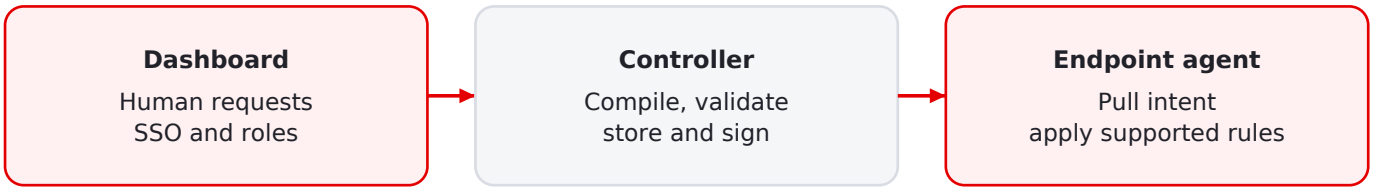
You asked whether management, discovery and firewalld control should use different ports. The current implementation uses route-specific identity/authorization on one HTTPS listener. Different listener ports require an explicit design decision and implementation; changing the public application port does not create them.

Source references [S2] [S4] [S9-S15]

IMPLEMENTATION ENABLERS

Supporting additions, separate from scope

The following choices support your features. They do not replace a requested outcome or make a partial requirement complete.



Application packet path: client -> endpoint kernel firewall -> local service.

Business application packets do not traverse the controller. The agent controls local firewalld.

Supporting component/control	Why it exists / requirement supported
Policy compiler and semantic digests	Resolve tags/groups/sources into per-endpoint intent; avoid meaningless version bumps. Compilation occurs inside controller transactions. Supports R04-R06/R19.
Health evaluator	Notice absent heartbeats and compare expected/observed state. Supports R03/R17; it does not close the policy-to-expectation gap by itself.
Separate traffic namespace + durable queue	Keep high-volume evidence ingestion separate from inventory/policy operations and support replay-safe processing. Supports R08-R10/R32.
mTLS and signed assignments	Authenticate endpoints and independently verify own-host policy authority/replay floors. Supports R02/R19/R22.
Private vault references and fixed local manager	Keep privileged service/configuration work narrow and auditable without arbitrary remote shell/Docker access. Supports R24-R30.
Independent rollback journals/watchdog	Recover exact owned rule state when ordinary agent execution fails. This is how the explicit rollback requirement R19 is implemented.
Bounded pools, indexes and HTTP serving	Reduce connection overhead and bound contention without caching authority. Supports R32.
Optional Slack/email/webhook delivery	Extend the requested dashboard alerts to external channels. Provider delivery remains separate operational acceptance.

Policy history and rollback themselves remain user requirements (R19). The specific hashes, journals, queue mechanics and signing algorithms are implementation choices.

Source references [S1] [S3-S5] [S8-S10] [S13]

HOW DELIVERY WILL BE DEMONSTRATED

Acceptance and the next pilot stage

R35 | 20-server pilot after checks; native/DC tests deferred DEFERRED

You asked: Test code properly before the 20-server pilot; leave real native OS and DC testing for later.

Achieved by: The implementation has recorded automated/controller/UI/agent checks and signed packages. Native RHEL 8/9, Ubuntu 26.04 and DC testing remain deferred at your request; live Entra acceptance is also outstanding.

Boundary / remaining: The real 20-server pilot has not started. Initial GUI kits remain monitor-only; discovery readiness is the first checkpoint.

Demonstration	Expected result / requirement
Install one endpoint	Authenticated inventory shows actual hostname/IPs/listeners without manual server creation (R02/R22).
Start 8443, move SSH to 2022	Next fresh discovery identifies actual service/port and highlights changes (R03).
Select Billing + 443, click count	Counts and opened rows share the same scope (R14).
Assign CSV/manual/subnet DCs	Manual precedence, nested /24 exception and conflicting DC withholding are visible (R11-R13).
Create group/service policy	Twenty targets receive the exact per-row source/port matrix (R04-R06/R38).
Learn 443 only	Only eligible 443 observations enter the frozen scope; evidence/export and retained-grant behavior are clear (R08-R10).
Remove an expected listener	Prior-up/explicit expected service alerts work; the allowed-policy expectation gap is separately tracked (R17).
Attempt risky mutation/failure	Independent review, exact protection, real management health and forced rollback pass on disposable native hosts before enforcement (R07/R19/R23).

R36 documentation: The illustrated architecture/operations guide and GUI pilot runbook explain components, communication ports, authentication, onboarding, agent packages, resource references and operating flow. This requirements document adds the explicit request-to-delivery mapping.

Recorded 0.6.1 checkpoint: controller 626 passed / 67 opt-in skips; integration 209 passed / 36 opt-in or Linux-only skips; dashboard 239 passed. Agent race/vet, Linux cross-builds, 27 installer cases and real HTTPS-kit-to-helper checks passed. Native/DC/live-tenant acceptance remains separate.

Source references [S9] [S13-S15]

TRACEABILITY REFERENCES

Evidence and document basis

Requirements faithfully paraphrase your conversation and corrections. Snapshot: 0.6.1. Application code, servers and settings were unchanged by this review. In source lists, abbreviated filenames share the preceding directory.

Ref	Evidence basis (paths relative to the standalone project)
S1	**Project scope and release** README.md; controller/__init__.py; output/gui-setup-0.6.1-validation.json
S2	**Inventory, discovery and health** controller/store.py; agent/internal/agent/discovery.go; inventory.go; deploy/systemd/seg-agent.service
S3	**Policy and reusable groups** controller/service_groups.py; application_groups.py; policy_views.py; docs/architecture.md
S4	**Baseline rules and enforcement** controller/firewall.py; managed.py; docs/managed-enforcement.md; agent/internal/agent/managed.go
S5	**Learning, automatic grants and export** controller/learning.py; learning_policies.py; evidence_views.py; agent/internal/agent/collector.go; learning_allow.go
S6	**Business metadata and IP/DC mapping** controller/metadata.py; metadata_csv.py; application_groups.py
S7	**Requested dashboard experience** dashboard/filters.js; routing.js; topology.js; account-menu.js; index.html; assets/README.md
S8	**Entra roles and independent review** controller/auth.py; approvals.py; docs/authentication.md
S9	**GUI-first controller/agent setup** controller/gui_setup.py; agent_installation.py; agent/internal/agent/setup_file.go; docs/pilot-gui-installation.md
S10	**Shared data, joining and runtime** docs/ha.md; controller/cluster_bootstrap.py; platform.py; platform_runtime.py; deploy/appliance/node_manager.py
S11	**GUI service/storage/TLS/port operations** controller/appliance.py; certificates.py; application_port.py; dashboard/settings-*.js
S12	**Backup schedules, cleanup and recovery** controller/maintenance.py; backup_schedule.py; recovery.py
S13	**Historical local capacity evidence** docs/controller-capacity-5000.md; output/capacity/controller-5000-result.json
S14	**Resources, VM sizes and packages** docs/agent-resources.md; controller-vm-requirements.md; output/gui-setup-0.6.1-validation.json
S15	**Scoped security assessment** docs/security-assessment-2026-10-31.md; current 0.6.1 validation report

Diagrams are original explanatory vector graphics, not screenshots of a deployed estate or evidence of DC failover. Reference measurements retain their stated workload limits. Private keys, passwords, tokens, customer inventory and database contents are not embedded.

Companion artifacts: the existing architecture/operations PDF and docs/pilot-gui-installation.md. This document is the requirements baseline for review, not an approval to enable enforcement.

Source references [S1-S15]